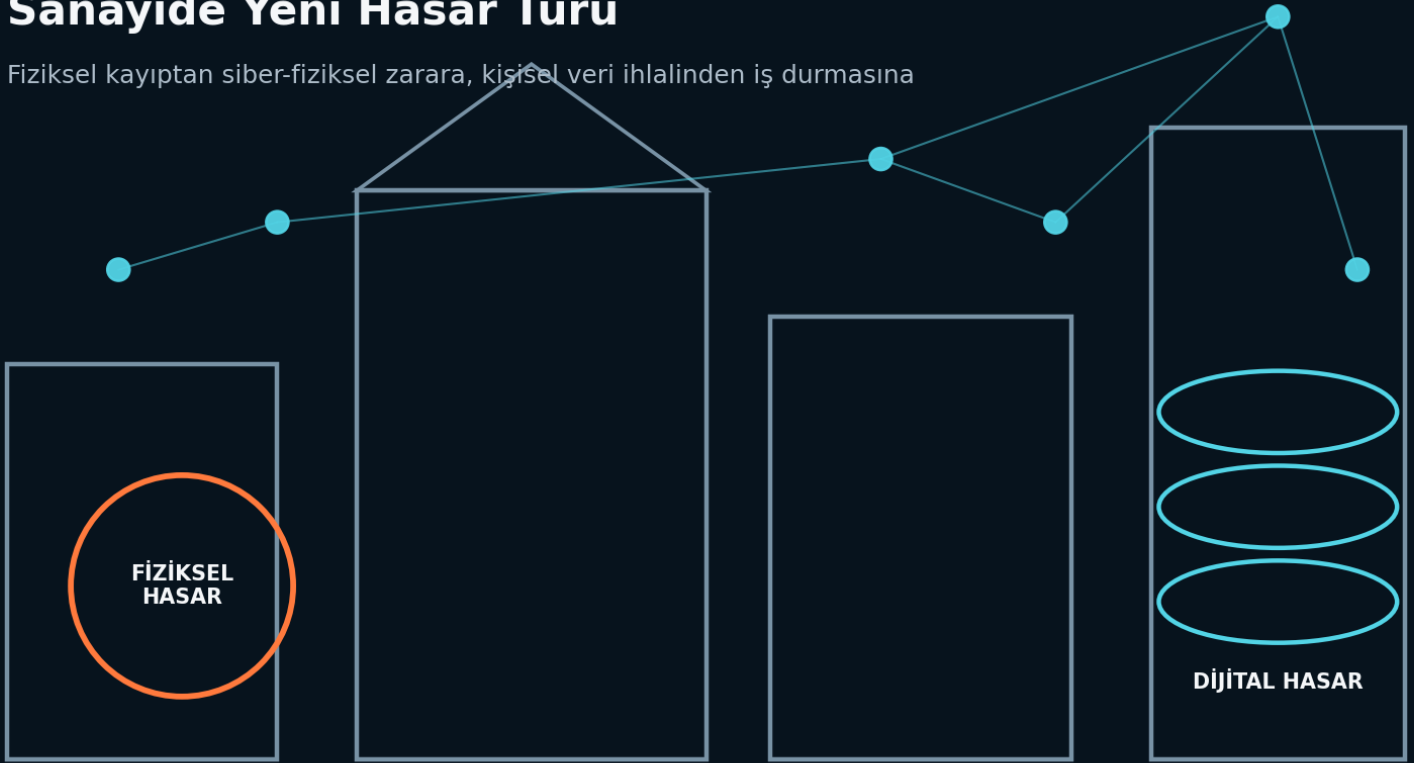


FABRİKALAR ARTIK SADECE YANMIYOR, VERİLERİ DE ÇALINIYOR

Sanayide Yeni Hasar Türü

Fiziksel kayıptan siber-fiziksel zarara, kişisel veri ihlalinin iş durmasına



5,50 MİLYON \$

IBM 2026 • endüstriyel sektörde ortalama veri ihlali maliyeti

%32

WEF 2026 • endüstriyel ortamların OT sistemlerini özel araçlarla aktif izleyenler

%20

WEF 2026 • özel OT güvenlik ekibine sahip olanlar

%16

WEF 2026 • OT güvenlik sorunlarını yönetim kuruluna raporlayanlar

VERİ NOTU

Oranlar ve maliyetler farklı araştırma evrenlerine aittir; birbirleriyle toplanamaz.

FABRİKALAR ARTIK SADECE YANMIYOR, VERİLERİ DE ÇALINIYOR

Sanayide Yeni Hasar Türü: Fiziksel kayıptan siber-fiziksel zarara, KVKK'dan iş durmasına

ÖZET — Sanayi tesislerinde klasik hasar dosyası yangın, patlama, elektrik arızası, makine kırılması ve doğal afet üzerinden kurulurdu. Dijitalleşme bu tabloyu değiştirdi. Günümüzde bir siber olay kişisel veriye yetkisiz erişimle sınırlı kalmayabilir; kimlik altyapısını, ERP/MES uygulamalarını, uzaktan bakım kanallarını ve IT/OT yakınsaması nedeniyle operasyon teknolojilerini etkileyerek iş durmasına, kalite veya güvenlik etkisine ve siber-fiziksel kayba dönüşebilir. World Economic Forum'un 2026 araştırması 804 nitelikli katılımcı ve 92 ülkeyi kapsamakta; endüstriyel ortamı bulunan kuruluşların yalnızca %16'sının OT güvenlik sorunlarını yönetim kuruluna raporladığını, %20'sinin özel OT güvenlik ekibine sahip olduğunu ve %32'sinin OT sistemlerini özel güvenlik araçlarıyla aktif izlediğini bildirmektedir [1]. IBM'in 2026 Cost of a Data Breach raporunda endüstriyel sektör için ortalama ihlal maliyeti 5,50 milyon ABD doları, küresel ortalama ise 4,99 milyon ABD dolarıdır [2]. Türkiye'de KVKK'nın 2026 tarihli Hyundai Motor Türkiye ve Tempo Makina ihlal ilanları çalışan, aday ve müşteri verilerinin sanayi ekonomisinin ayrı bir risk yüzeyine dönüştüğünü göstermektedir; bu ilanlar nihai kusur/yaptırım kararı değildir [10–11]. Makale, 'yeni hasar' kavramını veri, sistem, operasyon, proses güvenliği/çevre, hukuk ve ekonomi katmanlarını birlikte inceleyen adli mühendislik modeliyle ele almaktadır.

Anahtar kelimeler: sanayi, siber hasar, siber-fiziksel risk, IT/OT, OT/ICS, KVKK, 7545 sayılı Siber Güvenlik Kanunu, veri ihlali, iş durması, ransomware, dijital delil, adli bilişim, adli mühendislik, tedarik zinciri.

METODOLOJİK NOT — İstatistikler farklı araştırma evrenlerine aittir ve birbirleriyle toplanmamıştır. Kamuoyu veri ihlali duyuruları nihai kusur/yaptırım kararı sayılmamıştır. Hukuki hükümler olay tarihi ve somut kuruluş kapsamı bakımından ayrıca değerlendirilmelidir. Teknik önerilerde öncelik WEF/IBM/ENISA gibi kurumsal araştırmalara, KVKK/TBMM gibi birincil hukuk kaynaklarına ve NIST/IEC gibi teknik standart-rehber kaynaklarına verilmiştir.

1. Hasarın tanımı değişti

Bir fabrikanın hasar gördüğünü anlamak eskiden kolaydı: duvar kararmış, pano yanmış, makine durmuş veya stok zarar görmüştü. Siber olayda ise tesis dışarıdan normal görünebilir. Buna rağmen kimlik altyapısı kilitlenmiş, üretim reçetelerine erişim kesilmiş, müşteri ve çalışan verileri açılmış veya uzaktan bakım kanalı kötüye kullanılmış olabilir.

Bu nedenle sanayide yeni hasar, yalnızca “veri çalınması” değildir. Daha doğru tanım; dijital bir olayın veri gizliliği, sistem bütünlüğü, operasyonel kullanılabilirlik, üretim kapasitesi, sözleşmesel yükümlülük ve ekonomik süreklilik üzerinde yarattığı birleşik kayıptır.

2. Dünya verisi neden alarm veriyor?

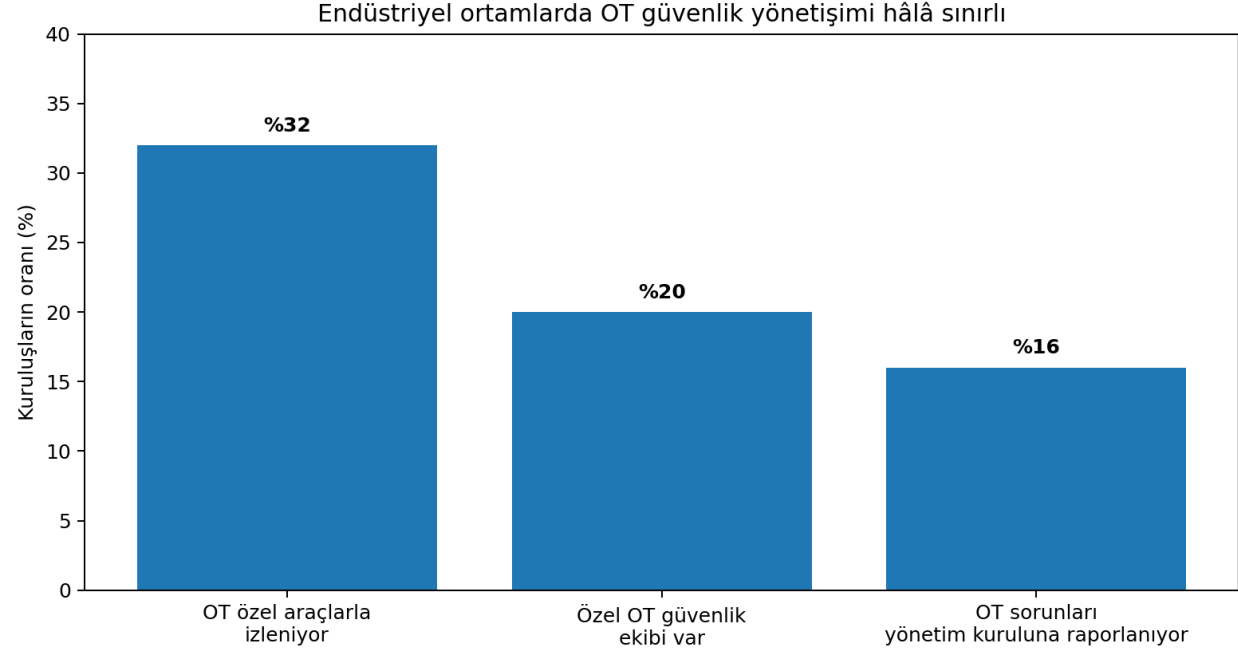
World Economic Forum'un Global Cybersecurity Outlook 2026 çalışmasının temel anketi 25 Ağustos–1 Ekim 2025 arasında yürütülmüş; 99 ülkeden 873 yanıtın demografik nitelik kontrolü sonrasında 92 ülkeden 804 nitelikli katılımcı analiz setinde kalmıştır. Katılımcılar arasında 316 CISO, 105 CEO ve 123 diğer C-seviye yönetici bulunmaktadır [1]. Ransomware, CISO'lar açısından önde gelen risk kaygısı olmayı sürdürürken rapor; üçüncü taraf, tedarik zinciri ve endüstriyel yakınsama risklerinin işletme dayanıklılığını doğrudan etkilediğini vurgulamaktadır.

OT yönetişimindeki boşluk daha çarpıcıdır: endüstriyel ortamı bulunan kuruluşların yalnızca %16'sı OT güvenlik sorunlarını yönetim kuruluna raporlamakta, %20'si özel OT güvenlik ekibi bulundurmakta, %32'si OT'yi özel güvenlik araçlarıyla aktif izlemekte ve yalnızca %36'sında OT güvenliğinden CISO doğrudan sorumludur [1]. Bu oranlar 'her fabrikada açık vardır' anlamına gelmez; yönetişim ve görünürlük olgunluğunun dijitalleşme hızının gerisinde kalabildiğini gösteren araştırma göstergeleridir.

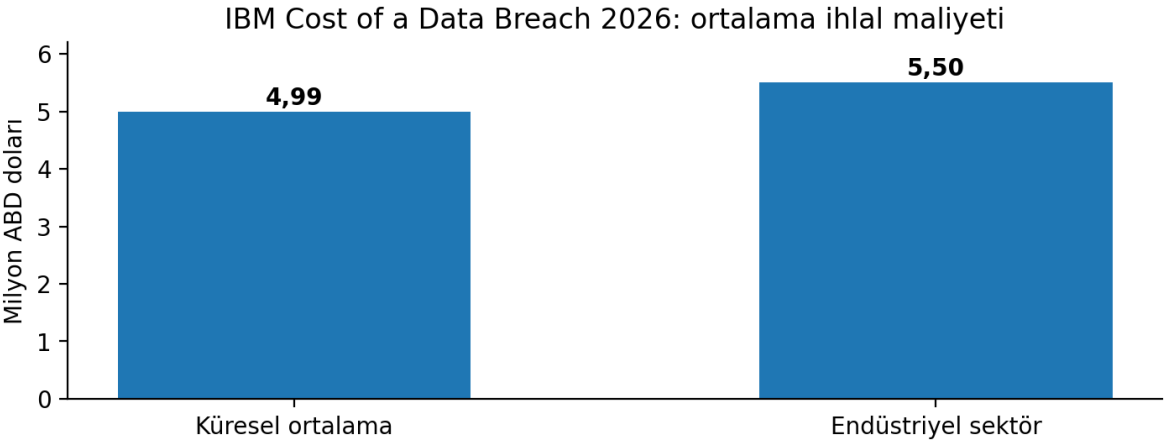
3. Veri ihlali sanayide neden pahalı?

IBM'in 2026 Cost of a Data Breach raporuna göre endüstriyel sektörde ortalama veri ihlali maliyeti 5,50 milyon ABD dolarıdır; aynı raporda küresel ortalama 4,99 milyon ABD dolarıdır [2]. 2026 çalışması ayrıca ortalama küresel maliyetin önceki yıla göre %12 yükseldiğini ve maliyet artışının önemli bölümünün tespit ve eskalasyon ile kaybedilen iş kalemlerinden geldiğini göstermektedir. Bu metnin eski taslağında yer alan 2024 tarihli 5,56 milyon ABD doları sanayi ortalaması kendi dönemi için doğru bir tarihsel veridir [3]; ancak 2026 tarihli yayın için güncel sektör karşılaştırmasında 5,50 milyon ABD doları esas alınmıştır.

Bu rakam Türkiye'deki herhangi bir fabrikanın beklenen kaybı olarak kullanılamaz; çok ülkeli örnekleminden türetilmiş bir ortalama. Somut olayda maliyet; olay müdahalesi ve adli bilişim, sistem kurtarma, üretim kaybı, güvenli yeniden başlatma, ek işçilik, hurda/yeniden işleme (rework), bildirim ve hukuki süreç, üçüncü taraf talepleri ile müşteri/tedarikçi etkileri gibi ayrı kalemlerden oluşabilir. Her kalem olayın zaman çizelgesi ve nedensellik bağıyla ispatlanmalıdır.



Şekil 1. WEF Global Cybersecurity Outlook 2026'da endüstriyel OT güvenlik yönetişi göstergeleri.



Not: Küresel ve endüstriyel ortalamalar belirli bir fabrikanın beklenen zarar tahmini değildir.

Şekil 2. IBM Cost of a Data Breach 2026: küresel ve endüstriyel ortalama veri ihlali maliyeti [2].

4. Türkiye'de yeni hasarın yüzü: KVKK ihlalleri

Türkiye'de 6698 sayılı Kanun'un 12'nci maddesi; kişisel verilerin hukuka aykırı işlenmesini ve erişilmesini önlemek, verilerin muhafazasını sağlamak amacıyla uygun güvenlik düzeyini temin edecek teknik ve idari tedbirlerin alınmasını öngörür [8]. Kanun'un 12/5 hükmündeki 'en kısa sürede' bildirim ifadesi Kurulun 24.01.2019 tarih ve 2019/10 sayılı kararıyla, veri sorumlusunun ihlali öğrendiği tarihten itibaren Kurula gecikmeksizin ve en geç 72 saat içinde bildirim yapması şeklinde yorumlanmıştır; ilgili kişilere bildirim ise etkilenen kişilerin belirlenmesini takiben makul olan en kısa sürede yapılmalıdır [9]. Bildirim için gerekli bilgilerin tümü ilk anda mevcut değilse aşamalı bildirim mümkündür; ihlal, etkileri ve alınan önlemler ayrıca kayıt altına alınmalıdır [9].

2026'da kamuoyuna açıklanan iki sanayi/otomotiv örneği riskin niteliğini somutlaştırmaktadır. Hyundai Motor Türkiye duyurusunda web uygulamasındaki SQL Injection açığının istismar edildiği, ihlalin 01.08.2026'da öğrenildiği, çalışan ve çalışan adaylarının ad-soyad, e-posta, değerlendirme sonuçları, kullanıcı adı, şifre ve unvan verilerinin etkilenmiş olabileceği ve etkilenen kişi sayısının en fazla 422 olabileceği açıklanmıştır; Kurulun 05.08.2026 tarih ve 2026/1634 sayılı kararıyla ilan yapılmış, incelemenin devam ettiği belirtilmiştir [10]. Tempo Makina duyurusunda ise 20.06.2026 tarihli siber saldırı sonucu yetkisiz erişim; çalışanlar ile müşteri/potansiyel müşteriler bakımından kimlik, iletişim, finans, görsel-işitsel, sağlık ve biyometrik veri dâhil geniş kategoriler açıklanmış, kişi/kayıt sayısının henüz belirlenemediği ve incelemenin sürdüğü bildirilmiştir [11]. Dolayısıyla kamuoyu duyurusu, tek başına nihai kusur veya yaptırım tespiti olarak okunmamalıdır.

5. IT ile OT arasındaki duvar incelidi

WEF 2026, IT ile OT arasındaki sınırın giderek belirsizleştiğini belirtirken NIST SP 800-82 Rev.3, OT güvenliğinin klasik IT kontrollerinden farklı olarak performans, güvenilirlik ve fiziksel/proses güvenliği (safety) gereksinimleriyle birlikte tasarlanması gerektiğini vurgular [1,5]. NIST; kurumsal ağ ile OT arasında DMZ/segmentasyon, yalnızca yetkili iletişime izin verilmesi ve OT'ye uzaktan erişimde iş ihtiyacıyla sınırlılık ile MFA gibi kontrolleri önerir [5]. IEC 62443-3-2 ise IACS mimarisinin risk temelli zone ve conduit yapılarına ayrılmasını ve her bölge/iletişim hattı için hedef güvenlik seviyelerinin belirlenmesini esas alır [7].

Bu yakınsama iki yönlü risk yaratır. Kurumsal IT'de başlayan kimlik ihlali kötü tasarlanmış bağlantılar üzerinden OT'ye yaklaşabilir; OT'deki kontrol veya görünürlük kaybı ise üretim, kalite, ekipman ve insan güvenliği sonuçlarına dönüşebilir. Buna karşılık her sanayi veri ihlalinin OT ihlali olduğu varsayılmaz. Teknik rapor; IT, OT, güvenlik sistemi ve saha etkisini delille ayırmalı, 'olabilir' ile 'gerçekleşti' ifadelerini birbirine karıştırmamalıdır. Uzun ömürlü veya artık desteklenmeyen IACS bileşenlerinde IEC 62443-2-1:2024, yerel teknik kabiliyetin yetersiz kaldığı haller için telafi edici güvenlik tedbirlerinin güvenlik programında ele alınabileceğini açıkça kabul eder [6].

6. Yangın ile siber olayın şaşırtıcı ortak noktası: olay yerini korumak

Yangın soruşturmasında kritik parçayı hurdaya göndermek nasıl kök nedeni yok edebilirse, siber olayda sistemi düşünmeden formatlamak, logları döndürmek veya saldırı izlerini temizlemek de dijital delili zayıflatabilir. Fakat OT ortamında 'delili korumak' üretimi ve güvenlik fonksiyonlarını riske atacak kör bir imaj alma işlemi anlamına gelmez. Delil toplama planı; operasyon, iş güvenliği/proses güvenliği, OT mühendisliği, adli bilişim ve hukuk ekipleriyle birlikte risk temelli kurulmalıdır [5].

Olayın niteliğine göre disk/bellek imajları, EDR kayıtları, firewall/proxy logları, Active Directory olayları, VPN kayıtları, SIEM korelasyonları ve gerekiyorsa PLC/HMI/historian olay kayıtları zaman çizelgesine alınabilir. NIST, zaman senkronizasyonunun log korelasyonu ve adli inceleme için önemini özellikle vurgular [5]. Delil bütünlüğü; hash değerleri, edinim yöntemi, yetkili kişi, tarih-saat ve muhafaza zinciriyle gösterilmelidir. Hash, delilin edinimden sonra değişmediğini destekler; içeriğin tek başına doğru yorumlandığını veya olayın nedenini ispatlamaz.

Yangın dosyası ile siber olay dosyası: farklı delil, benzer disiplin

FİZİKSEL HASAR

SİBER / DİJİTAL HASAR

Başlangıç	Alev / patlama / arıza	Kimlik ele geçirme / açık / zararlı yazılım
Delil	Yanık deseni, parça, numune	Log, disk/bellek imajı, EDR, ağ kaydı
Yayılım	Isı, duman, basınç	Yetki, ağ, tedarik zinciri, veri
Üretim etkisi	Makine/tesis kullanılamazlığı	IT/OT kesintisi, güvenli duruş, manuel işletme
Hasar miktarı	Onarım, yenileme, stok	IR, kurtarma, BI, veri ihlali, sözleşme
Kritik hata	Olay yerini erken temizlemek	Logları silmek / sistemi delilsiz yeniden kurmak

Şekil 3. Fiziksel hasar ve siber/dijital hasar soruşturmalarının karşılaştırılması.

7. Yeni hasarın altı katmanı

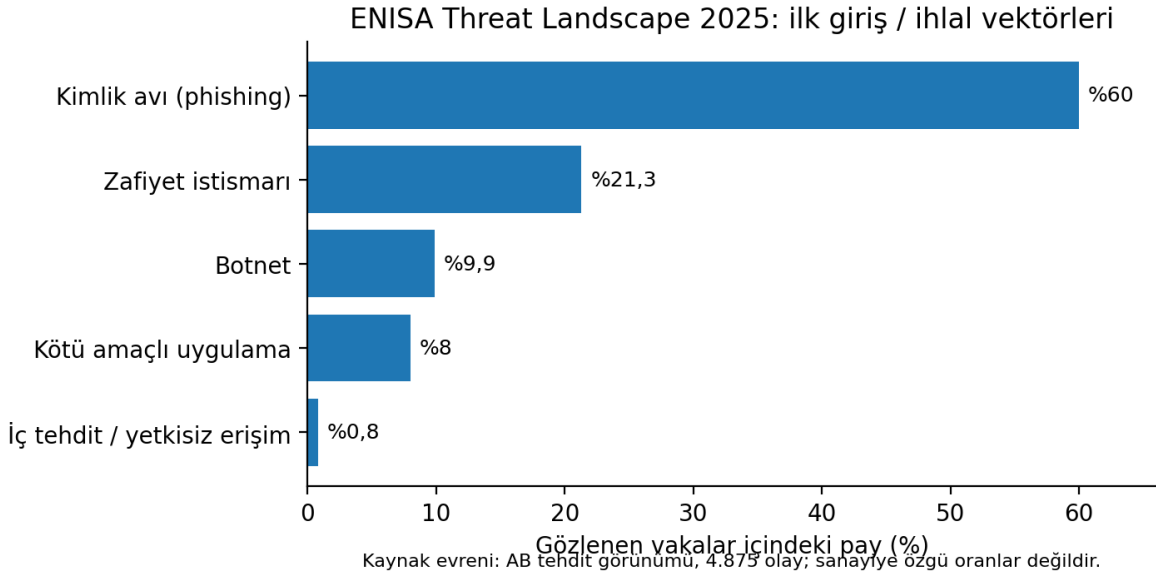
Bir sanayi siber olayında hasarın altı ayrı katmanda incelenmesi daha güçlü bir model verir. Birincisi veri hasarıdır: gizlilik, bütünlük veya erişilebilirlik kaybı. İkincisi sistem hasarıdır: sunucu, istemci, kimlik, bulut, uygulama veya kontrol sisteminin güvenilirliğini kaybetmesi. Üçüncüsü operasyonel hasardır: üretimin durması, kapasitenin düşmesi veya güvenli manuel işletmeye geçilmesi. Dördüncüsü proses güvenliği/çevresel etkidir: prosesin güvenli durumu, personel güvenliği, çevresel salım veya koruma sistemleri üzerindeki etkiler. Beşincisi hukuki/sözleşmesel etkidir: KVKK, 7545 sayılı Kanun kapsamında doğabilecek bildirimler, müşteri/tedarikçi yükümlülükleri ve delil saklama gereksinimleri. Altıncısı ekonomik hasardır: kurtarma, ek çalışma, iş durması, gecikme, hurda/yeniden işleme (rework) ve ispatlanabilir diğer ekonomik sonuçlar. NIST'in OT yaklaşımında fiziksel/proses güvenliğinin (safety) ayrı bir tasarım ve risk boyutu olması, bu katmanın veri/sistem etkisinden ayrı gösterilmesini destekler [5].

Bu katmanların aynı anda veya aynı ağırlıkta gerçekleşmesi şart değildir. Teknik mütalaa, her kalemi olayla nedensellik bağı kurarak ayrı ayrı göstermeli; zarar hesabında aynı kaybın birden fazla başlık altında mükerrer yazılmasını önlemelidir.

8. Ransomware neden sanayi için farklıdır?

Ransomware'in sanayideki etkisi dosyaların şifrelenmesinden daha geniş olabilir. WEF 2026, ransomware'in CISO'lar açısından önde gelen kaygı olmaya devam ettiğini ve başarılı bir saldırının kritik IT/OT kullanılabilirliğinde operasyonel kesinti yaratabileceğini vurgular [1]. ENISA Threat Landscape 2025 ise 1 Temmuz 2024–30 Haziran 2025 dönemindeki 4.875 olayı inceleyerek ransomware'i en doğrudan etkili siber suç tehditlerinden biri olarak değerlendirmektedir [4].

ENISA'nın sektörler arası AB veri setinde ilk giriş vektörlerinde phishing yaklaşık %60, zafiyet istismarı %21,3, botnet %9,9, kötü amaçlı uygulamalar %8 ve iç tehdit kaynaklı yetkisiz erişim %0,8 paya sahiptir [4]. Bu oranlar 'sanayiye özgü saldırı dağılımı' değildir ve fabrika risk modeliyle doğrudan eşitlenmemelidir. Adli inceleme; şifrelenen varlıkları, veri sızıntısını, kimlik altyapısını, yedeklerin durumunu, OT bağlantısını, güvenli duruş kararını ve üretim kesintisinin gerçek nedenini ayrı ayrı belirlemelidir.



Şekil 4. ENISA Threat Landscape 2025 veri setinde ilk giriş vektörlerinin dağılımı [4].

9. Tedarikçi artık fabrikanın görünmez kapısı

WEF 2026 araştırmasında üçüncü taraf yazılım, donanım ve hizmetlerin bütünlüğünü doğrudan güvence altına alamama 'miras alınan risk' (inheritance risk) olarak öne çıkmakta; görünürlük eksikliği özellikle enerji, üretim/tedarik zinciri/ulaştırma ve altyapı kümelerinde başlıca tedarik zinciri risklerinden biri olarak gösterilmektedir [1]. Yüksek dayanıklılığa sahip kuruluşların %74'ü tedarikçi güvenliğini değerlendirirken bu oran yetersiz dayanıklılık bildirenlerde %48'dir; ekosistemle olay simülasyonu oranları %44'e karşı %16, ekosistem/risk haritalama oranları ise %44'e karşı %23'tür [1].

Uzaktan bakım, OEM erişimi, yönetilen hizmet sağlayıcı, bulut ERP/MES, insan kaynakları platformu veya yazılım güncellemesi fabrikanın kendi güvenlik sınırının dışından risk taşıyabilir. Bu nedenle sözleşmelerde olay bildirim süresi, log saklama ve erişilebilirlik, MFA, erişim kapsamı/süresi, alt yüklenici kullanımı, denetim hakkı, zafiyet yönetimi, olay anında adli işbirliği ve veri/varlık iade-imha yükümlülükleri teknik risk yönetiminin parçası olmalıdır. NIST de OT olay müdahalesinde tedarikçi ve dış hizmet sağlayıcı rollerinin önceden planlanmasını önerir [5].

10. KVKK açısından 'tedbir aldık' cümlesi neden yetmez?

KVKK açısından 'tedbir aldık' ifadesi tek başına teknik yeterlilik kanıtı değildir. İnceleme; tedbirin olaydan önce var olup olmadığını, kapsamını, konfigürasyonunu, düzenli gözden geçirme ve test kayıtlarını, erişim yetkilerinin güncelliğini, zafiyet/patch yönetimini, yedek geri dönüş testlerini, log görünürlüğünü ve olay müdahale planının uygulanabilirliğini somut kayıtlarla sorgulamalıdır [8–9]. Kurulun 2019/10 kararı ayrıca ihlal müdahale planının hazırlanmasını ve belirli aralıklarla gözden geçirilmesini öngörür [9].

7545 sayılı Siber Güvenlik Kanunu da ayrı bir uyum katmanı oluşturur. Kanun m.7, Kanun kapsamındaki ve bilişim sistemleri kullanarak hizmet sunan/veri toplayan-işleyen benzeri faaliyet sahipleri bakımından, hizmet sundukları alanda tespit edilen zafiyet veya siber olayların Siber Güvenlik Başkanlığına gecikmeksizin bildirilmesini düzenler [12]. Bu yükümlülük KVKK'nın kişisel veri ihlali bildiriminden farklı tetikleyici, amaç ve merciye sahiptir; iki bildirim rejimi birbirinin yerine geçirilmemelidir. Somut kuruluşun kapsamı ve uygulanacak ikincil düzenlemeler olay tarihinde ayrıca kontrol edilmelidir.

11. Siber olayın iş durması hesabı nasıl yapılır?

Üretimin durduğu her dakika doğrudan saldırgana atfedilecek zarar değildir. Önce kritik yol kurulmalıdır: hangi dijital varlık hangi üretim fonksiyonunu durdurdu; güvenli duruş kararı ne zaman ve kim tarafından alındı; alternatif manuel/kısıtlı kapasite yöntemi var mıydı; kurtarma ve güvenli yeniden başlatma ne kadar sürdü; gecikmenin ne kadarı olayın zorunlu sonucu, ne

kadarı sonradan seçilen iyileştirme veya kapasite kararından kaynaklandı? Bu ayrım, teknik nedensellik ile ticari kayıp iddiasını birbirinden ayırır.

Nicelendirme için tek bir evrensel formül yoktur. Uygulanabilir bir adli mühendislik çerçevesi; olaya atfedilebilir katkı payı/üretim kaybı + makul ve zorunlu ek giderler + hurda/yeniden işleme (rework) + güvenli yeniden başlatma maliyetleri – kaçınılan giderler – olaydan bağımsız kesinti/iyileştirme süreleri – mükerrer veya geri kazanılmış tutarlar şeklinde kalem bazlı kurulabilir. ERP/MES kayıtları, makine/historian verileri, enerji tüketimi, OEE/kapasite verileri, sipariş-sevkiyat kayıtları, bordro/ek vardiya ve müşteri sözleşmeleri aynı zaman çizelgesinde çapraz doğrulanmalıdır. 'Ciro kaybı' otomatik olarak 'zarar' değildir; ispatlanabilir kayıp ve kaçınılan maliyetler ayrıştırılmalıdır.

12. Siber sigorta, fiziksel hasar sigortasının dijital kopyası değildir

Siber poliçeler; veri ihlali müdahalesi, adli bilişim, hukuki danışmanlık, bildirim, siber iş durması, bağımlı iş durması veya üçüncü taraf talepleri gibi farklı teminat yapıları içerebilir. Geleneksel mal sigortası ise fiziksel varlık hasarı ve buna bağlı iş durması üzerinden farklı koşullar taşıyabilir. Siber-fiziksel olaylarda fiziksel zarar, veri kaybı, bekleme süresi, hizmet sağlayıcı kesintisi ve istisna hükümlerinin kesişimi uyumsuzluk yaratabilir; teminat sonucu poliçe metnine ve somut olaya bağlıdır.

Bu nedenle teknik uzman poliçe yorumunu üstlenmeden olayın fiziksel ve dijital nedensellik zincirini, hangi sistemin neden devre dışı kaldığını, güvenli duruş kararının gerekçesini ve üretim kaybının hangi aşamada oluştuğunu açıkça ortaya koymalıdır. Hukuki nitelendirme ve teminat yorumu hukuk/sigorta uzmanlığının alanında kalırken, teknik dosyanın görevi olgu ile nedensellik bağını ölçülebilir delille kurmaktır.

Sanayide siber olayın yeni hasar zinciri



Yeni hasar türü tek başına 'veri kaybı' değildir; dijital olay fiziksel operasyon ve ekonomik sürekliliğe yayılabilir.

Şekil 5. Siber olayın sanayide teknik, hukuki ve ekonomik hasara dönüşme zinciri.

13. 12 noktalı özgün Sanayi Siber Hasar İnceleme Matrisi

Aşağıdaki matris bu makale için oluşturulmuş özgün adli mühendislik çalışma çerçevesidir; mevzuatta tanımlı zorunlu form, IEC/NIST'in birebir kopyası veya belirli bir olayın resmî bilirkişi raporu değildir. Amaç; teknik, delilsel, hukuki ve ekonomik inceleme adımlarının aynı olay zaman çizelgesinde unutulmadan yürütülmesidir.

Sanayi Siber Hasar İncelemesi: 12 Noktalı Adli Mühendislik Matrisi

01 Varlık + kritik proses IT, OT, bulut, veri, güvenlik-kritik fonksiyon	07 Delil + zaman çizelgesi EDR/SIEM/ağ/AD/VPN/PLC-HMI-historian; zaman senkronu
02 İlk erişim Kimlik, zafiyet, tedarikçi, fiziksel port	08 Hukuki bildirim / uyum KVKK ve 7545 tetikleyicilerini ayrı değerlendir
03 Kimlik / yetki MFA, ayrıcalıklı hesap, servis hesabı, erişim süresi	09 İş durması / nicelendirme Kritik yol, toparlanma eğrisi, kaçınılan giderler
04 Mimari / segmentasyon IT-OT sınırları, DMZ, zone/conduit, izinli akış	10 Tedarik zinciri OEM, MSP, bulut, yazılım güncellemesi, alt yüklenici
05 Veri etkisi Erişim, değiştirme, silme, exfiltration, IP/PII	11 Kurtarma / süreklilik Yedek, geri dönüş testi, manuel işletme, güvenli yeniden başlatma
06 OT / üretim / proses güvenliği Duruş, kapasite, kalite, güvenli durum, çevresel etki	12 Nedensellik / sorumluluk Teknik neden, katkı, sözleşme/sigorta sınırı, rücu

Bu matris mevzuatta tanımlı zorunlu form değildir; olay bazlı inceleme sırası ve delil disiplini standardize etmek için oluşturulmuş özgün çalışma çerçevesidir.

Şekil 6. Bu makale için güncellenen 12 noktalı Sanayi Siber Hasar İnceleme Matrisi.

14. Sanayi yönetim kurulunun sorması gereken 10 soru

01. En kritik üretim fonksiyonlarımız hangi IT ve OT varlıklarına bağımlı?
02. IT'den OT'ye geçişi sınırlayan gerçek segmentasyon kontrolleri var mı?
03. OEM ve uzaktan bakım erişimlerinin tamamı MFA, iş ihtiyacı, süre ve kapsam sınırı altında mı?
04. EDR/SIEM yalnızca ofis ağını mı, kritik endüstriyel varlıkları da mı görüyor?
05. Kritik IT/OT loglarının hangi zaman kaynağına göre ve ne kadar süre saklandığını gerçekten biliyor muyuz?
06. Kişisel veri envanterimiz, özellikle biyometrik/sağlık verileri, iş ihtiyacıyla sınırlı mı?
07. Yedekler saldırganın erişemeyeceği biçimde ayrılmış ve geri dönüş testi yapılmış mı?
08. Üretim güvenli biçimde manuel veya kısıtlı kapasitede sürdürülebilir mi?
09. Tedarikçi sözleşmeleri olay bildirimini ve adli delil işbirliğini düzenliyor mu?
10. Siber olayın iş durması, güvenli yeniden başlatma, KVKK/7545 bildirim ve sigorta senaryolarını masa başı veya teknik tatbikatta test ettik mi?

Sonuç

YENİ FABRİKA HASARI BAZEN DUMAN ÇIKARMADAN BAŞLAR. AMA ÜRETİMİ, VERİYİ VE BİLANÇOYU AYNI ANDA VURABİLİR.

Sanayide dijitalleşme, fiziksel ve siber hasar arasındaki sınırı kaldırmaktadır. Bir veri ihlali yalnızca mahremiyet olayı, ransomware yalnızca IT olayı, bir OT kesintisi yalnızca otomasyon arızası olarak ele alınamaz. Aynı olayın veri, sistem, operasyon, proses güvenliği/çevre, hukuk ve ekonomi katmanları farklı delil standartlarıyla ayrı ayrı incelenmelidir.

WEF 2026 verileri OT güvenlik yönetiminde önemli boşluklara işaret ederken IBM 2026 endüstriyel sektör için 5,50 milyon ABD doları ortalama ihlal maliyeti bildirmektedir [1–2]. ENISA'nın 4.875 olaylık AB tehdit görünümü phishing ve zafiyet istismarının ilk girişteki ağırlığını; Türkiye'deki KVKK ilanları ise çalışan ve müşteri verilerinin sanayi şirketleri için ayrı bir risk varlığı olduğunu gösterir [4,10–11]. Bunların hiçbirisi tek başına somut bir fabrikadaki kusur, zarar veya nedensellik sonucunu ispatlamaz.

Bu yeni hasar türünde en güçlü rapor, en dramatik saldırı hikâyesini anlatan değil; ilk erişimden veri etkisine, IT/OT yayılımından güvenli duruşa, bildirim yükümlülüğünden üretim kaybına kadar her halkayı dijital delil, teknik mimari, doğru zaman çizelgesi ve ekonomik kayıtlarla kanıtlayabilen rapordur. Sanayi siber olayının gerçek değeri de gerçek zararı da ancak disiplinler arası nedensellik kurulduğunda görünür hale gelir.

Kaynaklar

- [1] World Economic Forum. Global Cybersecurity Outlook 2026. 12.01.2026. Metodoloji: 804 nitelikli katılımcı / 92 ülke; OT yönetişi, ransomware, tedarik zinciri ve dayanıklılık göstergeleri.
 - [2] IBM. Cost of a Data Breach Report 2026. Küresel ortalama 4,99 milyon USD; endüstriyel sektör ortalaması 5,50 milyon USD.
 - [3] IBM. Cost of a data breach: The industrial sector. 2024 CODB tarihsel karşılaştırması: 5,56 milyon USD; 2023'e göre %18 artış.
 - [4] ENISA. Threat Landscape 2025, v1.2. 01.07.2024–30.06.2025 döneminde 4.875 olay; ilk giriş vektörleri ve ransomware/tehdit görünümü.
 - [5] NIST. SP 800-82 Rev.3, Guide to Operational Technology (OT) Security. Eylül 2023. OT performans, güvenilirlik, fiziksel/proses güvenliği (safety); segmentasyon/DMZ, uzaktan erişim, MFA, olay müdahalesi ve zaman senkronizasyonu.
 - [6] IEC 62443-2-1:2024. Security program requirements for IACS asset owners. Legacy IACS ve telafi edici güvenlik tedbirleri dâhil güvenlik programı gereksinimleri.
 - [7] IEC 62443-3-2:2020. Security risk assessment for system design. System under consideration, zone/conduit, risk değerlendirmesi ve hedef güvenlik seviyeleri.
 - [8] Kişisel Verileri Koruma Kurumu. 6698 sayılı Kanun m.12 çerçevesi ve Kişisel Veri Güvenliği rehberleri: uygun teknik ve idari tedbir yükümlülüğü.
 - [9] Kişisel Verileri Koruma Kurulu. 24.01.2019 tarih ve 2019/10 sayılı Karar: ihlalin öğrenilmesinden itibaren Kurula gecikmeksizin ve en geç 72 saatte bildirim; kayıt, aşamalı bildirim ve müdahale planı.
 - [10] Kişisel Verileri Koruma Kurumu. Hyundai Motor Türkiye Otomotiv AŞ veri ihlali kamuoyu duyurusu; Kurul 05.08.2026 tarih ve 2026/1634 sayılı Kararı.
 - [11] Kişisel Verileri Koruma Kurumu. Tempo Makina Pazarlama AŞ veri ihlali kamuoyu duyurusu; Kurul 24.06.2026 tarih ve 2026/1268 sayılı Kararı.
 - [12] 7545 sayılı Siber Güvenlik Kanunu. Kabul: 12.03.2025; özellikle m.2 kapsam ve m.7 sorumluluklar/bildirim yükümlülüğü.
- Veri ve hukuk notu: Makale 11.08.2026 tarihinde erişilebilen kamuya açık ve ağırlıkla birincil/kurumsal kaynaklarla güncellenmiştir. Standart ve rehberler hukuki zorunlulukla eşitlenmemiş; mevzuat hükümleri ise somut kuruluş ve olay tarihine göre ayrıca uygulanmalıdır.



YAZAR

Melike Özlem BİLGİLİ

Akademisyen - Elektrik Elektronik
Yüksek Mühendisi

uzmanmutaalasi.com

+90 532 642 26 57

info@uzmaninceleme.com

Adli mühendislik • elektrik • bilişim
endüstriyel hasar • uzman mütalaası

Yazar künyesi

Bu yayın kamuya açık kaynaklara dayalı bilimsel/teknik değerlendirmedir. Somut bir siber olay, sigorta poliçesi, KVKK veya 7545 sayılı Kanun incelemesi bakımından nihai kusur, kapsam, teminat, tazminat, idari yaptırım ya da hukuki sorumluluk tespiti değildir.